CYRO

Intelligent Cybersecurity Platform

دليل الشرح والعرض

منصة أمن سيبراني تفاعلية تعمل محليا بالكامل ودون إنترنت: أدوات فحص، مركز عمليات SOC، مختبر محاكاة هجمات، خريطة هجمات مباشرة، مختبر اتصال آمن بتشفير حقيقي، ومحرك كشف واستجابة دفاعية آلية. الفكرة المختصرة: «نرى الهجوم، نكشفه، نوقفه، ونثبت أننا أوقفناه».

1. خطة عرض مقترحة (5 دقائق)

- الدقيقة 1 · لوحة التحكم: اشرح حالة النظام والبطاقات والخريطة. «كل رقم هنا يأتي من قاعدة البيانات لا من أرقام ثابتة».
- الدقيقة 2 · مختبر المحاكاة: اختر DDoS وسرعة 1× ثم ابدأ. شاهد الأقواس تنبعث من المصادر نحو الخادم، ثم تتحول للأخضر بعد الحظر.
- الدقيقة 3 · مركز SOC: افتح تبويب الحوادث وانقر الحادثة: الخط الزمني، الإجراءات، «تم التحقق»، ثم نزل تقرير PDF.
- الدقيقة 4 · مختبر الاتصال الآمن: بلا حماية اختر «تعديل الرسالة» وأرسل: ينجح الهجوم. فعل «حماية CYRO الكاملة» وكرر: يرفض ويكتشف.
- الدقيقة 5 · الأدوات: ألصق رابطا مشبوها في فاحص الروابط، وجرب كلمة مرور في المحلل، ثم بدل اللغة للعربية/الإنجليزية لإظهار RTL/LTR.

نصيحة: شغل المشروع قبل العرض بساعة وجرب كل خطوة مرة واحدة.

2. شرح كل صفحة

لوحة التحكم

تجمع الصورة الكاملة: حالة أمان النظام (آمن/مرتفع/حرج حسب الحوادث الفعلية)، إجمالي الأحداث، التهديدات المكتشفة والمحظورة، التنبيهات الحرجة، الحوادث النشطة، مع نسبة التغير عن الساعة السابقة. تحتها خريطة الهجمات، خط الكشف الزمني، توزيع الخطورة، إحصاءات الهجمات، أكثر المصادر حظرا، وقائمة «كشف التهديدات» القابلة للتوسيع، ثم نتائج أدوات الفحص.

خريطة الهجمات

خريطة عالم منقطة تعمل دون إنترنت. عند كل حدث يرسم قوس من المصدر إلى الخادم المحمي: أحمر = الهجوم نفذ، أخضر = حظر، أزرق = مستخدم محلي. مصادر المحاكاة تعرض بأسماء SIM-01 إلى SIM-16 لأنها عناوين اختبار محجوزة بلا موقع حقيقي، ولا تمثل دولا فعلية.

مركز العمليات SOC

- المراقبة المباشرة: بث الأحداث لحظة حدوثها مع الخريطة ومعدل الأحداث.
- إدارة التنبيهات: اعتماد أو حل أو إعادة فتح كل تنبيه.
- تتبع الحوادث: تفاصيل، خط زمني من الكشف حتى التقرير، إجراءات دفاعية، إغلاق الحادثة، وتقرير PDF بالعربية والإنجليزية.
- قواعد الكشف: كل قاعدة بمعرف وشروط وخطورة وعدد التنبيهات.
- السجلات الأمنية: كل الأحداث مع مرشحات (النوع، النتيجة، الجلسة).

مختبر المحاكاة (Attack Lab)

خمسة سيناريوهات: تخمين كلمات المرور، فحص المنافذ، DDoS، التصيد، وكشف الملفات المشبوهة. لكل سيناريو وصف الهجوم وطريقته والهدف التعليمي، وأزرار: بدء، إيقاف مؤقت، استئناف، إيقاف، إعادة ضبط، وسرعة 0.5×/1×/2×. كل سيناريو يتضمن سلوكا عاديا (مثل مستخدمة أخطأت مرة في كلمة المرور) لإثبات أن النظام لا يتهم الأبرياء.

مختبر الاتصال الآمن (Secure Communication Lab)

يحاكي مرسلا وقناة ومهاجما ومستقبلا. تكتب رسالة وترسلها وترى الحزمة تتحرك على القناة. يمكنك اختيار هجوم من خمسة: التنصت، تعديل الرسالة، إعادة الإرسال، انتحال المرسل، والوسيط MITM، وتفعيل أربع طبقات حماية:

- التشفير AES-256-GCM: يخفي المحتوى ويكشف أي تعديل.
- التوقيع الرقمي ECDSA: يثبت هوية المرسل وسلامة الحزمة.
- تبادل مفاتيح موثق: يمنع الوسيط من استبدال المفاتيح.

- منع إعادة الإرسال: رقم تسلسلي وختم زمني.

التشفير والتوقيع حقيقيان عبر Web Crypto المدمجة في المتصفح، والمهاجم كائن محلي يعمل على البايتات نفسها، فنتائج الرفض تأتي من فحص تشفيري فعلي لا من نص ثابت. تظهر بعد كل إرسال مؤشرات: نتيجة الهجوم، السرية، السلامة، التسليم، وكشف CYRO، مع جملة تشرح الدرس.

ما تثبته التجارب (مهم للشرح): التشفير وحده لا يوقف إعادة الإرسال ولا هجوم الوسيط؛ التوقيع وحده لا يمنح سرية؛ والتنصت السلبي لا يمكن كشفه، فالحماية الوحيدة منه هي التشفير.

أدوات الفحص

- فاحص الروابط: تحليل محلي للنطاق وHTTPS وانتحال العلامات والنطاقات المختصرة وغيرها، مع فحص شهادة HTTPS، ويحجب فحص العناوين الداخلية وlocalhost. لا يتتبع التحويلات عمدا.
- كاشف التصيد: قواعد عربية وإنجليزية (استعجال، تهديد، طلب بيانات، روابط)، ويفسر كل مؤشر.
- محلل كلمات المرور: يعمل في المتصفح فقط، لا يرسل ولا يحفظ.
- سلامة الملفات: SHA-256، مقارنة ملفين أو مع Hash، وقت التعديل، وسجل تغييرات الملفات. الـ Hash يثبت السلامة ولا يكشف البرمجيات الخبيثة.
- اختبار الوعي الأمني: 12 سؤالا تصحح في الخادم مع شرح كل إجابة. التقارير: PDF بالعربية والإنجليزية.

3. مسار الدفاع النشط

هجوم ← كشف ← تحليل ← إنشاء حادثة ← استجابة آلية ← تحقق ← احتواء ← تقرير. كل مرحلة تسجل بوقتها. الإجراءات: حظر المصدر، قفل الحساب، حظر النطاق، عزل الرسالة أو الملف، إبطال مفتاح الجلسة، وفرض التشفير. التحقق فعلي: بعد الإجراء يرسل النظام حدثا اختباريا عبر المرشح نفسه ويجب أن يرفض، وإلا تبقى الحادثة «فشل التحقق». الحظر يجري في جدار حماية محاكى داخل قاعدة البيانات ولا يمس الجهاز أو الشبكة.

4. قواعد الكشف (11 قاعدة)

- CR-BF-001 تخمين كلمات المرور: 5 محاولات فاشلة أو أكثر من مصدر واحد خلال 60 ثانية.
- CR-PS-001 فحص المنافذ: 8 منافذ مختلفة أو أكثر من مصدر واحد خلال 10 ثوان.
- CR-ST-001 حركة غير طبيعية: أكثر من 100 طلب أو 50 ميغابايت من مصدر واحد خلال 10 ثوان.
- CR-ST-002 إغراق موزع DDoS: 120 طلبا أو أكثر من 8 مصادر فأكثر نحو هدف واحد خلال 5 ثوان.
- CR-PH-001 رسالة تصيد: درجة التحليل 50 فأكثر (حرجة من 80).
- CR-UR-001 رابط خطير: درجة الفحص 50 فأكثر.
- CR-ML-001 ملف مشبوه: توقيع EICAR الاختباري، تنفيذي متنكر، امتداد مزدوج، أو Hash اختباري معروف.
- CR-CM-001 فشل سلامة أو أصالة رسالة: وسم GCM أو توقيع ECDSA غير صالح.
- CR-CM-002 إعادة إرسال: رقم تسلسلي قديم أو ختم زمني خارج 30 ثانية.
- CR-CM-003 العبث بتبادل المفاتيح (احتمال MITM): توقيع المصافحة لا يطابق الهوية الموثقة. حرجة.
- CR-CM-004 بيانات حساسة عبر قناة غير مشفرة: سياسة تفرض التشفير بعد الكشف.

حدود الكشف مضبوطة لتناسب العرض المباشر ومكتوبة في شروط كل قاعدة داخل صفحة القواعد.

5. التقنيات والبنية

- الخلفية: Python وFlask، وقاعدة SQLite (وضع WAL). الواجهة: HTML وCSS وJavaScript صرف بلا أطر.
- البث المباشر: Server-Sent Events (مدمجة في المتصفح) بدل WebSocket لأنها لا تحتاج مكتبات إضافية.
- التشفير: Web Crypto API (ECDH P-256 وHKDF-SHA256 وAES-256-GCM وECDSA P-256).
- التقارير: reportlab مع arabic-reshaper وpython-bidi لدعم العربية، وخط DejaVu المرفق.
- الخريطة: بيانات Natural Earth (ملك عام) محولة إلى نقاط وتعمل دون إنترنت.
- اللغة والاتجاه: عربي/إنجليزي مع RTL/LTR فوري، وتصميم متجاوب للهاتف واللوحي والكمبيوتر.
- الجودة: 21 اختبارا آليا بلغة Python و9 اختبارات للتشفير بـ Node، إضافة إلى اختبارات المتصفح الفعلية.

6. إجراءات الأمان في المشروع

- CSRF على كل طلبات POST، وتحديد معدل الطلبات، وسياسة CSP صارمة بلا سكربتات أو أنماط مضمنة.
- حماية SSRF: حجب localhost والشبكات الخاصة، وتثبيت عنوان IP عند فحص الشهادة.
- استعلامات SQL معلمة بالكامل، وتحقق صارم من مدخلات واجهات المحاكاة والاتصال.
- لا تحفظ كلمات المرور ولا الملفات ولا نصوص الرسائل، ولا ينفذ أي ملف.

• كل الهجمات محاكاة محلية: عناوين اختبار محجوزة (RFC 5737)، ولا اتصال خارجي.

7. أسئلة متوقعة من اللجنة وإجاباتها

هل يستخدم المشروع ذكاء اصطناعيا؟

لا. «الذكي» يعني التحليل والاستجابة الآليين بقواعد معلنة ومفسرة، وليس نموذج تعلم آلي. نعتبر الشفافية ميزة: كل تنبيه يمكن شرح سببه.

هل الهجمات حقيقية؟ هل تضر بالشبكة؟

لا. كلها محاكاة داخل المشروع، والمصادر عناوين اختبار محجوزة، ولا يرسل أي شيء خارج الجهاز.

هل التشفير حقيقي أم عرض فقط؟

حقيقي. نستخدم Web Crypto: مفاتيح ECDH وAES-256-GCM وتوقيعات ECDSA. عندما يعدل المهاجم بتا واحدا يفشل فحص GCM فعلا، ويمكن رؤية الحزمة الفعلية في لوحة «ما يمر على القناة».

لماذا لا يكتشف النظام التنصت؟

لأن التنصت السلبي لا يترك أثرا على القناة، وهذه حقيقة في الأمن. لذلك الحماية منه تكون بالتشفير، وقد أبرزناها كدرس داخل المختبر.

كيف يحظر النظام المهاجم؟ وهل يمس الشبكة؟

الحظر يتم في جدار حماية محاكى (جدول في قاعدة البيانات) تمر عبره أحداث المحاكاة. بعد الحظر نرسل حدثا اختباريا للتحقق أنه رفض. لا يمس نظام التشغيل ولا الشبكة الحقيقية.

ما حدود المشروع؟

• لا يوجد نظام حسابات: يستمع على 127.0.0.1 فقط لجهاز العرض.
• فاحص الروابط لا يتتبع سلاسل التحويل عمدا لتجنب الاتصال بمواقع غير موثوقة.
• الفحوصات الحقيقية للأدوات لا ترسم على الخريطة لأن موقعها غير معروف، ولا نختلق لها موقعا.
• حدود القواعد مضبوطة لتناسب العرض المباشر؛ في بيئة حقيقية تضبط حسب الحركة الفعلية.
• ميزة تحميل قائمة URLhaus الاختيارية وفحص شهادات مواقع حقيقية لم تختبر على إنترنت فعلي.

8. التشغيل واستكشاف الأخطاء

• المرة الأولى فقط تحتاج إنترنت: انقر run.bat وسيثبت المكتبات (Flask وreportlab وarabic-reshaper وpython-bidi). بعدها يعمل دون إنترنت. جهز ذلك قبل المعرض.
• يتطلب Python 3.10 أو أحدث مع خيار Add Python to PATH، ثم افتح http://127.0.0.1:5000
• افتح الموقع دائما عبر 127.0.0.1 أو localhost: مختبر الاتصال يحتاج Web Crypto وهي لا تعمل عبر عنوان شبكة محلي عادي.
• إن كان المنفذ 5000 مشغولا غير رقمه في آخر سطر من app.py.
• لبدء عرض نظيف: احذف ملف data/cyberguard.db وأعد التشغيل، أو استخدم أزرار «إعادة الضبط» داخل المختبرين.
• إن ظهرت العربية متقطعة في PDF فتأكد من وجود مجلد backend/fonts بملفات DejaVu.

الاختبارات: python -m unittest discover tests و node tests/comm_core.test.js